

Incident Runbooks and Final Documentation

AWS Production Hardening Sprint

Prepared by Prasanna Patil

Purpose First-response guidance for the error-rate and latency alarms across all four serverless projects, plus a controlled final-submission index.

RUNBOOK INDEX

- 06 Leave Management System — Submit leave request → approval workflow → balance update → employee notification
- 07 Internal Learning Management System — Course assignment → quiz attempt → completion → certificate generation and email
- 08 Automated Employee Onboarding — Employee creation → Cognito identity → document collection → provisioning → welcome email
- 09 AI Powered Resume Screener — Resume upload → Textract → Comprehend → SQS scoring → DynamoDB → recruiter dashboard

OPERATING RULES

- Acknowledge alerts immediately and preserve alarm time, region, correlation ID, and affected resource.
- Use safe test data; disable real external notifications during incident testing.
- Never log authentication tokens, passwords, resume text, full email addresses, phone numbers, or unredacted employee data.
- Retry only after checking idempotency and partial completion; do not create duplicate balances, certificates, identities, assets, candidates, or paid AI calls.
- An incident closes only after the alarm is OK for two evaluation periods and the full critical flow succeeds.

FINAL SUBMISSION STATUS

- Included now: four incident runbooks and the supplied production-hardening technical document.
- Add before submission: dashboard screenshot, IAM comparison, cost workbook, CI/CD evidence, and Artillery report. Do not mark them complete without matching screenshots or reports.

Incident Runbook Leave Management System

Severity	SEV 2 by default • Raise to SEV 1 for security, data-integrity, or broad service impact
Critical flow	Submit leave request → approval workflow → balance update → employee notification

Alarm meaning Error-rate alarm: more than 5% Lambda errors for two consecutive 5-minute periods. Latency alarm: Lambda P95 duration above 3,000 ms for two consecutive 5-minute periods.

POSSIBLE CAUSES

- 401: missing, invalid, or expired Cognito JWT; approval HMAC token expired
- 403: valid user lacks the required Manager/HR group or route permission
- DynamoDB AccessDenied on the single-writer balance update, conditional conflict, or throttling
- Step Functions state failure, timeout, or malformed state input
- SES/SNS failure, cold start, workflow wait/retry, or downstream latency

BUSINESS IMPACT

Employees may be unable to submit requests; approvals or leave balances may be delayed or inconsistent; notifications may not reach managers or employees.

FIRST RESPONSE

1. Acknowledge the SNS alert; note alarm name, UTC time, region, and affected function.
2. For 401, validate Bearer header, 60-minute JWT expiry/issuer/audience; issue a fresh approval token instead of reviving an expired one. For 403, verify Manager/HR group claims and authorizer policy.
3. Search logs using the correlation ID; inspect the X-Ray trace and the related Step Functions execution.
4. For DynamoDB AccessDenied, identify the denied action and verify the execution role has the exact table/index ARN; do not broaden access to Resource *.
5. Stop unsafe retries if a balance could be applied twice. Correct the issue, then retry only the failed workflow using its idempotency key.

RECOVERY VERIFICATION

- Complete one safe test: submit → approve → balance update → notification.
- Confirm alarm returns to OK for two periods; no new errors or throttles appear.
- Verify the request status and leave balance match, with only one notification sent.

ESCALATION CONDITIONS

- Error/latency remains breached for 15 minutes after first response.
- Multiple users are affected, data integrity is uncertain, or duplicate balance updates occurred.
- IAM/KMS access, AWS regional service health, or security exposure is suspected.

Recovery evidence to attach Alarm history; Log Insights result; X-Ray trace ID; Step Functions execution ARN; test request ID; incident timeline.

Incident Runbook Internal Learning Management System

Severity	SEV 2 by default • Raise to SEV 1 for security, data-integrity, or broad service impact
Critical flow	Course assignment → quiz attempt → completion → certificate generation and email

Alarm meaning Error-rate alarm: more than 5% Lambda errors for two consecutive 5-minute periods. Latency alarm: Lambda P95 duration above 3,000 ms for two consecutive 5-minute periods.

POSSIBLE CAUSES

- 401: missing, invalid, or expired Cognito JWT; 403: learner/admin group mismatch
- Quiz/course data mismatch or attempts-limit validation failure
- DynamoDB AccessDenied on completion write, conflict, or throttling
- S3 certificate encryption/PutObject permission error
- PDF timeout, oversized content, or SES delay/rejection

BUSINESS IMPACT

Learners may be unable to submit quizzes, completion status may not save, certificates may be missing, or certificate emails may be delayed.

FIRST RESPONSE

1. Acknowledge the alert and record alarm, time, region, course ID, and correlation ID.
2. For 401/403, validate JWT expiry/issuer/audience, group claim, Cognito authorizer, and route protection; GET /verify/{cert_id} is the intentional public exception.
3. Determine whether failure is in grading, completion write, PDF generation, S3 storage, or SES delivery using logs and X-Ray.
4. For AccessDenied, match the denied DynamoDB/S3 action to the exact resource ARN; never restore wildcard permissions.
5. Retry certificate generation idempotently only after confirming no valid certificate already exists. Never consume another quiz attempt during recovery.

RECOVERY VERIFICATION

- Run a test quiz and confirm one completion record is stored.
- Open the generated PDF from the expected S3 key and validate the public verification endpoint if used.
- Confirm email status and that alarms remain OK for two periods.

ESCALATION CONDITIONS

- Failures continue for 15 minutes or affect multiple courses/users.
- Quiz attempts or completion records are inconsistent, lost, or duplicated.
- Certificates expose incorrect learner data, S3 access is public, or AWS dependency degradation is suspected.

Recovery evidence to attach Alarm graph; correlation ID; quiz/completion IDs; Lambda logs; S3 object key; SES event; test result.

Incident Runbook Automated Employee Onboarding

Severity	SEV 2 by default • Raise to SEV 1 for security, data-integrity, or broad service impact
Critical flow	Employee creation → Cognito identity → document collection → provisioning → welcome email

Alarm meaning Error-rate alarm: more than 5% Lambda errors for two consecutive 5-minute periods. Latency alarm: Lambda P95 duration above 3,000 ms for two consecutive 5-minute periods.

POSSIBLE CAUSES

- 401: expired/invalid Cognito JWT; 403: HR/admin group or route permission mismatch
- Cognito user creation, duplicate username, quota, or permission error
- Missing employee data/document or Step Functions retry exhaustion
- DynamoDB single-writer, S3, IAM, or KMS AccessDenied
- Cognito/SES delay, workflow wait state, or downstream latency

BUSINESS IMPACT

New hires may not receive access, required steps may remain incomplete, Day-1 readiness can be delayed, and HR may see incorrect onboarding status.

FIRST RESPONSE

1. Acknowledge the alert and capture employee ID, execution ARN, failed state, UTC time, and region.
2. For 401/403, validate JWT expiry/issuer/audience, HR/admin group claim, Cognito authorizer, and protected-route configuration.
3. Use logs, X-Ray, and execution history to isolate the task; for AccessDenied, verify the exact table/bucket/KMS ARN on the execution role.
4. Check whether accounts/assets were partially provisioned before retrying; prevent duplicate users, assets, or emails.
5. Correct the issue, then resume/redrive from the failed state when supported or start a controlled compensating workflow.

RECOVERY VERIFICATION

- Confirm each mandatory workflow state completes and dashboard status is accurate.
- Verify one Cognito user, correct document status, asset/account state, and one welcome email.
- Confirm alarm is OK for two periods and no executions remain unexpectedly stuck.

ESCALATION CONDITIONS

- Critical onboarding is blocked or breach persists for 15 minutes.
- Partial provisioning cannot be reconciled, credentials were exposed, or duplicate identities/assets exist.
- An AWS regional issue, IAM/KMS failure, or security incident is suspected.

Recovery evidence to attach Alarm history; execution ARN; failed-state input/output with PII redacted; user ID; test employee ID; recovery timeline.

Incident Runbook AI Powered Resume Screener

Severity	SEV 2 by default • Raise to SEV 1 for security, data-integrity, or broad service impact
Critical flow	Resume upload → Textract → Comprehend → SQS scoring → DynamoDB → recruiter dashboard

Alarm meaning Error-rate alarm: more than 5% Lambda errors for two consecutive 5-minute periods. Latency alarm: Lambda P95 duration above 3,000 ms for two consecutive 5-minute periods.

POSSIBLE CAUSES

- 401: missing/expired Cognito JWT; 403: recruiter group or route permission mismatch
- Unsupported, corrupt, encrypted, or oversized resume
- Textract/Comprehend throttling, timeout, quota, or malformed response
- SQS backlog, poison message, visibility mismatch, or DLQ growth
- DynamoDB AccessDenied/throttling or large OCR/NLP workload

BUSINESS IMPACT

Resumes may remain unprocessed, candidate profiles or rankings may be delayed/incomplete, recruiter decisions may use stale data, and processing cost may rise through repeated OCR/NLP calls.

FIRST RESPONSE

1. Acknowledge the alert; record job ID, document hash, message ID, correlation ID, region, and alarm.
2. For 401/403, validate JWT expiry/issuer/audience, recruiter group claim, Cognito authorizer, and route protection; GET /health is the public exception.
3. Locate the failed stage using metrics, logs, X-Ray, queue age/depth, and DLQ. Never log resume text or PII.
4. For AccessDenied, match the denied DynamoDB/S3/SQS action to the exact ARN; also validate KMS, quotas, visibility timeout, and retries.
5. Quarantine poison documents. Redrive only failed messages and use the document hash to avoid duplicate Textract/Comprehend charges.

RECOVERY VERIFICATION

- Process one safe test resume end to end and confirm a single candidate record and score.
- Verify queue depth/oldest age returns to normal and DLQ does not grow.
- Confirm recruiter dashboard fields populate and alarms stay OK for two periods.

ESCALATION CONDITIONS

- Backlog age or alarm breach persists for 15 minutes, or DLQ grows continuously.
- Candidate data is lost, duplicated, exposed, or rankings are materially incorrect.
- AWS quota/regional outage, unexpected cost spike, IAM/KMS issue, or security incident is suspected.

Recovery evidence to attach Alarm graph; job/message IDs; redacted logs; X-Ray trace; SQS/DLQ metrics; candidate ID; cost/retry note.